Lab 24 — SIEM Basics with Wazuh Manager (single-node)

You will spin up a Wazuh manager via the all-in-one installer, ingest auth + audit logs, and pivot from a brute-force alert to the offending IP.

Run on https://killercoda.com/playgrounds/scenario/ubuntu (use the **2 hour** session — install takes ~5 min)

Required software (free): - Wazuh server (open-source SIEM) - `curl` (pre-installed)

Step 1 — Install Wazuh all-in-one

```
curl -sO https://packages.wazuh.com/4.9/wazuh-install.sh
bash wazuh-install.sh -a -i 2>&1 | tail -20
```

Wait until the script prints the dashboard URL, username (`admin`), and generated password.

Step 2 — Confirm services

```
systemctl status wazuh-manager --no-pager | head -5
systemctl status wazuh-indexer --no-pager | head -5
```

```
ss -tlnp | grep -E "1514|55000|9200"
```

`1514` = agent traffic, `55000` = REST API, `9200` = OpenSearch.

Step 3 — Register a local agent

```
/var/ossec/bin/manage_agents -a -n local -i 127.0.0.1 -q
KEY=$(/var/ossec/bin/manage_agents -e 001 | tail -1)
/var/ossec/bin/manage_agents -i "$KEY" -q
```

Install + start the agent:

```
curl -sO https://packages.wazuh.com/4.x/apt/pool/main/w/wazuh-agent/wazuh-agent_4.9.0-1_amd64.deb
WAZUH_MANAGER='127.0.0.1' dpkg -i wazuh-agent_4.9.0-1_amd64.deb
systemctl enable --now wazuh-agent
```

Step 4 — Generate brute-force evidence

```
for i in $(seq 1 10); do ssh -o PubkeyAuthentication=no -o
StrictHostKeyChecking=no \
    baduser@127.0.0.1 2>/dev/null; done
```

Wait 30 seconds, then check the manager:

```
tail -50 /var/ossec/logs/alerts/alerts.log
grep -E "rule_id|level" /var/ossec/logs/alerts/alerts.log | tail
```

You should see rule 5712 ("SSHD brute force") at level 10.

Step 5 — Query via the REST API

```
TOKEN=$(curl -sk -u wazuh-wui:wazuh-wui -X POST
https://localhost:55000/security/user/authenticate | jq
-r .data.token)
curl -sk -H "Authorization: Bearer $TOKEN"
"https://localhost:55000/manager/stats" | jq | head
```

Step 6 — Build a saved search in the dashboard

Open https://:443, log in as `admin`, **Discover** → **security-alerts-***, filter `rule.id:5712`. The matching IP appears in the `srcip` column — that is the SOC pivot point.

Free online tools

- **Wazuh docs** — https://documentation.wazuh.com
- **The ELK stack (Elastic free tier)** — https://www.elastic.co
- **Splunk Free (500 MB/day)** — https://www.splunk.com/en_us/download/splunk-enterprise.html
- **Graylog Open** — https://www.graylog.org/products/source-available
- **Sigma rules** (open SIEM detections) — https://github.com/SigmaHQ/sigma
- **MITRE ATT&CK Navigator** — https://mitre-attack.github.io/attack-navigator/

What you learned

- How a SIEM aggregates logs, normalises, and triggers correlation rules.
- That a single rule ID (5712) is enough to pivot from raw logs to attacker IP.
- Why the REST API matters for SOAR/automation pipelines.